INFORMATIVE REPORT

Number: ASC X9F IR 01-2025

Title: Post-Quantum Cryptography Financial Readiness Needs Assessment Informative Report

Developed by: The X9 Quantum Computing Risk Study Group

Informative Reports developed through the Accredited Standards Committee X9, Inc. ("X9"), are copyrighted by X9. Informative Reports are available free of charge however, all copyrights belong to and are retained by X9. For additional information, contact the Accredited Standards Committee X9, Inc. at ASC X9, Inc., 275 West Street, Suite 107, Annapolis, Maryland 21401

© ASC X9, Inc., 2025 – All Rights Reserved

Table of Contents

Page

DRAFT INFORMATIVE REPORT .....
Acronyms and Abbreviations 1
1 Executive Summary 3
2 Overview 3
3 Scope 5
4 Data Value and Lifecycle 6
4.1 Determining Data Value 6
4.2 How Long Does the Data Require Protection? 7
5 Cryptographic Audit and Inventory 8
5.1 Cryptographic Inventory 9
5.1.1 Stored Corporate Assets 9
5.1.1.1 Digital Wallet/Vault 10
5.1.1.2 Password Safe or Key Safe (software) 10
5.1.1.3 PKI Certificates 10
5.1.2 Data Delivery Channels for Data in Transit 11
5.1.3 Third Parties, Contractors, and Suppliers 12
5.2 Cryptographic Risk Assessment 13
6 Building A Migration Plan 14
6.1 Remediation Best Practices 15
6.2 Cryptography Life Cycle Management 16
6.2.1 Cryptographically Agile Architectures 17
6.2.2 Cryptography Bill of Materials (CBOM) 19
6.3 Crypto Asset Management 20
6.4 Cryptographic Interoperability 20
6.5 Cryptography Policy Orchestration 21
7 Design Trade-offs and Identifying Dependencies 23
8 Certificate Implementations and Interoperability 23
8.1 Pure Quantum-safe Certificates 24
8.2 Composite Quantum-safe Certificates 24
8.3 Related Certificates 24
8.3.1 Chameleon Certificates 24
8.3.2 Dual-Key Certificates 25
9 Compliance Assurance 25
10 What New Attacks Could Result from Combining Quantum Computers and AI 27
11 Consider Cloud Service Providers a Vulnerable Point in IT Infrastructure 27
12 Related Work by X9 28
13 Conclusion 28
Annex A – NIST-Approved Post-Quantum Cryptographic Algorithms 29

©ASC X9 Inc. 2025 – All Rights Reserved

Foreword

This Informative Report has been approved and released by the Accredited Standards Committee X9, Incorporated, located at 275 West Street, Suite 107, Annapolis, MD 21401. This document is copyrighted by X9. It is not an American National Standard and the material contained herein is non-normative in nature. Comments on the content of this document should be sent to: Attn: Executive Director, Accredited Standards Committee X9, Inc., 275 West Street, Suite 107, Annapolis, MD 21401,

This Informative Report was produced by the Accredited Standards Committee X9 Financial Industry Standards. It was generated by the Quantum Computing Risk Study Group, established by the X9 Board of Directors in December 2017 to research the state of quantum computing and to generate a report summarizing the findings of the group.

Suggestions for improvement or revision of this report are welcome. They should be sent to the X9 Committee Secretariat, Accredited Standards Committee X9, Inc., Financial Industry Standards, 275 West Street, Suite 107, Annapolis, MD 21401 USA.

Published by

Accredited Standards Committee X9, Incorporated, Financial Industry Standards ("ASC X9" or "X9")

275 West Street, Suite 107

Annapolis, MD 21401 USA

X9 Online: http://www.x9.org

Copyright © 2025 ASC X9, Inc.

Some graphics generated by AI

All rights reserved.

No part of this publication may be reproduced in any form, in an electronic retrieval system or otherwise, without prior written permission of the publisher. Published in the United States of America. Members of ASC X9 are granted permission to distribute copies of this publication within their company.

X9 Board of Directors (List of Members):

At the time this Informative Report was published, the ASC X9 Board of Directors had the following member companies and company representatives and X9 had the following staff:

Corby Dear, X9 Board of Directors Chair

Michelle Wright, X9 Board of Directors Vice Chair

Steve Stevens, X9 Executive Director

Janet Busch, Director of Operations

Ambria Calloway, Program Manager

Lindsay Conley, Project Manager

Organization Represented	***Representative***
Amazon	Smita Mahapatra
American Bankers Association	Karin Flynn
American Bankers Association	Ananda Radhakrishnan
American Bankers Association	Tab Stewart
American Bankers Association	Shannon Williams
American Express Travel Related Services Company	Matt Crothers
American Express Travel Related Services Company	Lauren Helt
American Express Travel Related Services Company	Brian Politz
American Express Travel Related Services Company	Wayne Powell
American Express Travel Related Services Company	Sophie Rainford
Bank of America	Rich Clow
Bank of America	Chuck Gruesbeck
Bank of America	Matt Sharp
Bank of America	Michael Smith
Bank of New York Mellon	Kevin Barnes
BankVOD	Sean Dunlea
Bloomberg LP	Erik Anderson
Bloomberg LP	Corby Dear
Bloomberg LP	Rich Robinson
Capital One	Matthew Hines
Capital One	Diana Muse
Citigroup, Inc.	Sudha Iyer
Communications Security Establishment	Jonathan Hammell
Conexxus, Inc.	Michael Davis
Conexxus, Inc.	David Ezell
Conexxus, Inc.	Gray Taylor
Conexxus, Inc.	Alan Thiemann
CUSIP Global Services	Matthew Bastian
CUSIP Global Services	Roger Fahy
CUSIP Global Services	Gerard Faulkner
CUSIP Global Services	Scott Preiss
Deluxe Corporation	Margiore Romay
Deluxe Corporation	Andy Vo
Diebold Nixdorf	Bruce Chapa
Diebold Nixdorf	Anne Konecny
Diebold Nixdorf	Alexander Lindemeier
Digicert	Dean Coclin

©ASC X9 Inc. 2025 – All Rights Reserved

Digicert	Tim Hollebeek
Discover Financial Services	Carey Ferro
Discover Financial Services	Gregory Wren
Dover Fuleing Solutions	Harish Veeravalli
Early Warning Systems	Adam Klappholz
Early Warning Systems	Mark McInnes
FactSet Research Systems Inc	Michele Lieber
Federal Reserve Bank	Ainsley Hargest
Federal Reserve Bank	Mark Kielman
FirstBank	Ryan Buerger
FIS	Prashant Gupta
FIS	Tami Harris
FIS	Cary Jeffers
FIS	Gail Lumsden
FIS	Prajoy Prabhakaran
FIS	Gary Sliger
FIS	Joe Stein
Fiserv	Andrea Beatty
Fiserv	Jacqueline Dill
Fiserv	Dan Otten
FIX Protocol Ltd - FPL	James Northey
Futurex	Ryan Smith
Harland Clarke/Vericast	Todd Herndon
Harland Clarke/Vericast	Andy Marek
Hyosung TNS Inc.	JaeWhan Shin
IBM Corporation	Richard Kisley
Ingenico	Steven Bowles
Ingenico	Wayne Burgess
Intuit, Inc.	Naresh Karri
Invenco by GVR	Bruce Welch
ISITC	Jason Brasile
ISITC	Lisa Iagatta
ISITC	Rich Robinson
ITS, Inc. (SHAZAM Networks)	Scott Green
ITS, Inc. (SHAZAM Networks)	Manish Nathwani
J.P. Morgan Chase	Andrew Francis
J.P. Morgan Chase	Clinton Jones
J.P. Morgan Chase	Ted Rothschild
Keyfactor	Tomas Gustavsson
MasterCard Europe Sprl	Mark Kamers
Member Emeritus	Todd Arnold
Member Emeritus	Andi Coleman
Member Emeritus	Roy DeCicco
Member Emeritus	Dave Faoro
Member Emeritus	Valerie Hodge
Member Emeritus	Darlene Kargel
Member Emeritus	Bill Poletti
Member Emeritus	Diane Poole
Member Emeritus	Ralph Poore
Member Emeritus	David Repking
Member Emeritus	Mark Tiggas
Member Emeritus	Daniel Welch
Merchant Advisory Group	Troy Carrothers
Merchant Advisory Group	Steve Cole
Merchant Advisory Group	Bryan Penny
Nacha The Electronic Payments Association	Kathy Levin

©ASC X9 Inc. 2025 – All Rights Reserved

National Security Agency	Mike Boyle
NCR Atleos	Charlie Harrow
NCR Atleos	Gordon Mackay
NCR Voyix	Jackie Farone
Office of Financial Research, U.S. Department of the Treasury	Paul D'Amico
Office of Financial Research, U.S. Treasury Department	Jennifer Bond-Caswell
Office of Financial Research, U.S. Treasury Department	Thomas Brown Jr.
PCI Security Standards Council	Doug Manchester
PNC Bank	Melinda Tobolewski
Safari SOP	Steve Jatnieks
Safari SOP	Tom Melling
SWIFT/Pan Americas	Anne Suprenant
TECSEC Incorporated	Ed Scheidt
TECSEC Incorporated	Jay Wack
Thales DIS CPL USA Inc	James Torjussen
The Clearing House	Jackie Pagán
Thomson Reuters	Kyle Floyd
Thomson Reuters	Taimur Javed
U.S. Bank	Bob Walker
U.S. Bank	Michelle Wright
U.S. Commodity Futures Trading Commission (CFTC)	Ken Janoski
U.S. Commodity Futures Trading Commission (CFTC)	Robert Stowsky
University Bank	Stephen Ranzini
University Bank	Michael Talley
USDA Food and Nutrition Service	Lisa Gifaldi
USDA Food and Nutrition Service	Sara Klos
VeriFone, Inc.	Joachim Vance
Viewpointe Clearing, Settlement and Associations Services, LLC	Richard Luchak
VISA	Andreas Aabye
VISA	Adam Clark
VISA	Eric Le Saint
VISA	Kim Wagner
Wells Fargo Bank	Sotos Barkas
Wells Fargo Bank	Peter Bordow
Wells Fargo Bank	Dawn Elliot
Wells Fargo Bank	Alan Nguyen
Wells Fargo Bank	Jeff Stapleton
Wolters Kluwer	Andrea Hearn
Wolters Kluwer	Sayuj Nambiar

X9F Quantum Computing Risk Study Group Members

At the time this informative report was published, the X9F Quantum Computing Risk Study Group had the following officers and members:

Steve Stevens, Study Group Co-Chair

Tim Hollebeek and Philip Lafrance, Study Group Co-Chair

Organization Represented	***Representative***
Accenture	Benjamin McCarty
Accredited Standards Committee X9, Inc.	Janet Busch
Accredited Standards Committee X9, Inc.	Ambria Calloway

©ASC X9 Inc. 2025 – All Rights Reserved

Accredited Standards Committee X9, Inc.	Lindsay Conley
Accredited Standards Committee X9, Inc.	Steve Stevens
Ally Financial	Lisa Matthews
American Express Travel Related Services Company	Vinay Singh
American Express Travel Related Services Company	Alejandro Vences
American Express Travel Related Services Company	Kevin Welsh
BP	Cigin Joseph
British Telecommunications	Nigel Tedeschi
Capital One	Johnny Lee
Capitol Technology University	Amare Geremew
Cisco	Scott Fluhrer
Citigroup, Inc.	Sudha Iyer
Citigroup, Inc.	Michael King
Common Crypto Authority	Troy Anderson
Communications Security Establishment	Jonathan Hammell
Communications Security Establishment	Erin McAfee
Conexxus, Inc.	David Ezell
CryptoNext Security	Ludovic Perret
Diebold Nixdorf	Alexander Lindemeier
Digicert	Tim Hollebeek
Discover Financial Services	Benjamin Artus
Discover Financial Services	Dhaval Chauhan
Federal Reserve Bank	Troy Campbell
Federal Reserve Bank	Scott Gaiti
Federal Reserve Bank	Dillon Glasser
Federal Reserve Bank	Ray Green
Federal Reserve Bank	Terry Harris
Federal Reserve Bank	Mark Kielman
Federal Reserve Bank	Francois Leclerc
Federal Reserve Bank	Jeffrey Ronay
Federal Reserve Bank	Fabio Sanches
Federal Reserve Bank	Chris Tsuboi
FIX Protocol Ltd - FPL	James Northey
GIS Quantum Solutions Practice	Steven Jasmin
Harrisburg University	Terrill Frantz
HSBC Banking	Chris Ratcliff
IBM Corporation	Marcone Almeida
IBM Corporation	Wai Choi
IBM Corporation	Anne Dames
IBM Corporation	Erick de Carty
IBM Corporation	Mike Hocker
IBM Corporation	Richard Kisley
IBM Corporation	Sunil Landge
IBM Corporation	Michael Osborne
Imperial College London	Andrew Mendelsohn
Ingenico	Laurent Pion
Introspect Tech	Tony Thompson
Invenco by GVR	Scott Spiker
Invenco by GVR	Bruce Welch
ISARA Corporation	Philip Lafrance
Itaú Unibanco SA	Joao Vieira da Silva
Mayo Clinic School of Medicine	Horacio Murillo
Member Emeritus	Todd Arnold
Member Emeritus	Andi Coleman
Member Emeritus	Larry Hines
Member Emeritus	Bill Poletti

©ASC X9 Inc. 2025 – All Rights Reserved

Member Emeritus	Ralph Poore
Member Emeritus	Richard Sweeney
National Security Agency	Mike Boyle
National Security Agency	Austin Calder
National Security Agency	Nick Gajcowski
Office of Financial Research, U.S. Treasury Department	Jennifer Bond-Caswell
Office of Financial Research, U.S. Treasury Department	Lynn Calahan
Office of Financial Research, U.S. Treasury Department	Michael Warner
OpenText	Timothy Roake
Performance Food Group	Pinkaj Klokkenga
PNC Financial Services Group	Stephanie DeCarlo
Publix Super Markets, Inc.	Josh Peak
Qrypt	Denis Mandich
Quantum Bridge Technologies Inc.	Melchior Aelmans
Quantum Bridge Technologies Inc.	Mattia Montagna
Quantum Bridge Technologies Inc.	Paul O'Leary
Quantum Bridge Technologies Inc.	Bill Wyche
Richter Inc.	David Lachmansingh
Sympatico	Mary Horrigan
TECSEC Incorporated	Ed Scheidt
TECSEC Incorporated	Jay Wack
Thales DIS CPL USA Inc	Amit Sinha
The Clearing House	Joel Bucklew
The Clearing House	Jackie Pagán
U.S. Bank	Vikram Andem
University Bank	Michael Talley
University of Maryland	Jonathan Katz
University of Waterloo	Chin Lee
University of Waterloo	Michele Mosca
Utimaco Inc.	Jillian Benedick
VeriFone, Inc.	John Barrowman
VeriFone, Inc.	Chetan Katira
VeriFone, Inc.	Joachim Vance
VISA	Yilei Chen
VISA	Adam Clark
VISA	Naga Vinod Duggirala
VISA	Eric Le Saint
VISA	Peihan Miao
VISA	Kim Wagner
VISA	Gaven Watson
Wells Fargo Bank	Alexandria Archer
Wells Fargo Bank	Peter Bordow
Wells Fargo Bank	Shannon Chang
Wells Fargo Bank	Sarah Chen
Wells Fargo Bank	Kelle Clark
Wells Fargo Bank	Josh Cooper
Wells Fargo Bank	Joe Janas
Wells Fargo Bank	Rameshchandra Ketharaju
Wells Fargo Bank	Antoinette McCarthy
Wells Fargo Bank	Abhijit Rao
Wells Fargo Bank	Juan Rodriguez
Wells Fargo Bank	Jeff Stapleton
Wells Fargo Bank	Tony Stieber
Wells Fargo Bank	Hunter Storm
West Point Education	Lubjana Beshaj
Whitebox Advisors	Kerry Manaster

©ASC X9 Inc. 2025 – All Rights Reserved

Acronyms and Abbreviations

AES	Advanced Encryption Standard (symmetric encryption)
ANSI	American National Standards Institute - https://www.ansi.org/
CP	Certification Authority
CBC	Cipher block chaining
CCA	Common Cryptographic Architecture
CISA	US Cybersecurity and Infrastructure Security Agency - https://www.cisa.gov/
CSRC	Computer Security Resource Center (NIST) - https://csrc.nist.gov/
CVC	Card verification code used by MasterCard
CVV	Card verification value used by VISA
DEA	Data Encryption Algorithm
DES	Data Encryption Standard
DSA	Digital Signature Algorithm
DUKPT	Derived Unique Key Per Transaction
EC	Elliptic Curve
ECC	Elliptic Curve Cryptography
ETSI	European Telecommunications Standards Institute - https://www.etsi.org/
FIPS	Federal Information Processing Standards
FPE	Format Preserving Encryption
MAC	Message Authentication Code
MK	Master Key
ML-DSA	Module-Lattice-Based Digital Signature Algorithm
ML-KEM	Module-Lattice-Based Key-Encapsulation Mechanism
NSA	US National Security Agency - https://www.nsa.gov/
NIST	US National Institute of Science and Technology - https://www.nist.gov/
OID	Object Identifier
OWASP	Open Web Application Security Project - https://owasp.org/
PAN	Personal Account Number
PKI	Public key infrastructure
PQC	Post Quantum Cryptography
QKD	Quantum Key Distribution
RNG	Random Number Generator
RSA	Rivest, Shamir, and Adleman

© ASC X9 Inc., 2025 – All Rights Reserved

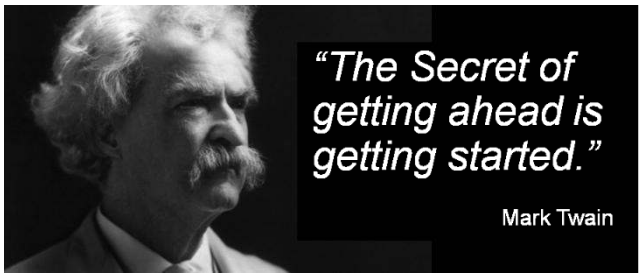
SCT	Signed Certificate Timestamp
SHA	Secure Hash Algorithm
SLH-DSA	Stateless Hash-Based Digital Signature Algorithm
TDES	Triple DES (Data Encryption Standard)
X9 or ASC X9	Accredited Standards Committee X9 Inc. http:www.x9.org

© ASC X9 Inc., 2025 – All Rights Reserved

ASC X9F IR 01-2025
Post-Quantum Cryptography Financial Readiness Needs Assessment Informative Report

ASC X9 - Post Quantum Cryptography Financial Industry Readiness Needs Assessment Informative Report

1 Executive Summary



The transition to post-quantum cryptography (PQC) will not necessarily be quick or inexpensive. However, ignoring the issue will likely lead to more costly missteps and increase the risk of overlooking potential issues, resulting in greater time and financial losses. Implementing a companywide program to investigate internal security issues related to quantum computing, and to create plans to address them, provides the best opportunity for reducing migration expenses, creating an environment secure against quantum attack, reducing the likelihood of missed vulnerabilities, and providing the opportunity to correct long-standing problems. While the scope of the work may be daunting, the financial industry has faced similar challenges in the past with other cryptographic migrations, such as DES to 3DES, SHA1 to SHA2, and 3DES to AES.

The fundamental difficulty in achieving an effective migration to PQC is the scale and effort required across multiple industry sectors, systems, and networks. Put another way, the cryptographic migration task is a complex problem involving change at multiple levels. In addition to these complexities, the timeline for implementation must also be considered.

Like any complex or challenging problem, simplification is a good way to start. The problem can be more easily managed by breaking it down into a prioritized sequence of individual steps. However, in terms of the PQC migration, building such a list involves understanding the requirements of the standards community, vendors, and end-users.

This document and others being produced by X9 will aid organizations preparing to migrate to PQC. For more information on related documents, please visit the X9 website (www.x9.org) or contact X9 (admin@x9.org).

2 Overview

The Cybersecurity and Infrastructure Security Agency (CISA) defines "National Critical Functions" (NCF)[1] as "functions of government and the private sector so vital to the United States that their disruption, corruption, or dysfunction would have a debilitating effect on security, national economic security, national public health or safety,

[1] CISA, NCF, https://www.cisa.gov/topics/risk-management/national-critical-functions

© ASC X9 Inc., 2025 – All Rights Reserved

or any combination thereof". Several of the 55 currently-defined NCFs directly relate to activities of the Financial Services Industry, with several more pertaining to the provisioning and maintenance of cybersecurity. The goal of this document is to provide a high-level overview of options, alternatives, and guidance for mitigating the cybersecurity threats posed by quantum computers to the Financial Services Industry.

The key challenge for X9 is to educate the financial industry on how to identify, analyze, prioritize, and manage not only the significant risks posed by a future quantum computer but also how the industry will migrate to post-quantum cryptography (PQC) to protect against these types of attacks.

PQC is a branch of cryptography concerned with asymmetric cryptographic systems resistant to attacks which utilize either quantum computers or classical computers. Standards bodies like ASC X9 are working with organizations like the National Institute of Standards and Technology (NIST) to select secure PQC algorithms and incorporate them into our financial standards. That said, the effort to standardize a suite of PQC algorithms is still a work in progress with an initial set of post-quantum-algorithms expected by late 2024. In 2024, NIST has released their first batch of three PQC algorithms. More details on these algorithms can be found in Annex A of this document. NIST has started work on the next round of PQC candidates[2].

The migration to PQC will, by necessity, require significant work in many areas, such as:

- Educating personnel on the issues related to how quantum computers can break cryptography.
- Creating a cryptographic asset inventory to identify all the cryptographic systems in use.
- Prioritize current systems for remediation based on a risk assessment.
- Developing and implementing a plan to migrate to PQC solutions where required.
- Working with vendors to develop and deploy PQC solutions in third party products.
- Using the PQC migration as an opportunity to investigate and incorporate features of an agile architecture where appropriate.

Companies and government agencies are facing a critical challenge: the need to migrate to post-quantum cryptography in order to protect sensitive data and networks from attacks by quantum computers.

This paper provides guidance for the financial industry, government agencies, and other organization to help them prepare for the migration to PQC. In addition, this paper also identifies the challenges that companies and agencies will face in migrating to PQC. These include:

- The need to educate personnel on quantum computing issues and the new PQC algorithms.
- There may be a need to select between multiple PQC algorithms for a given use case.
- The cost of developing and deploying PQC solutions.
- The need to coordinate the migration across multiple organizations and networks.

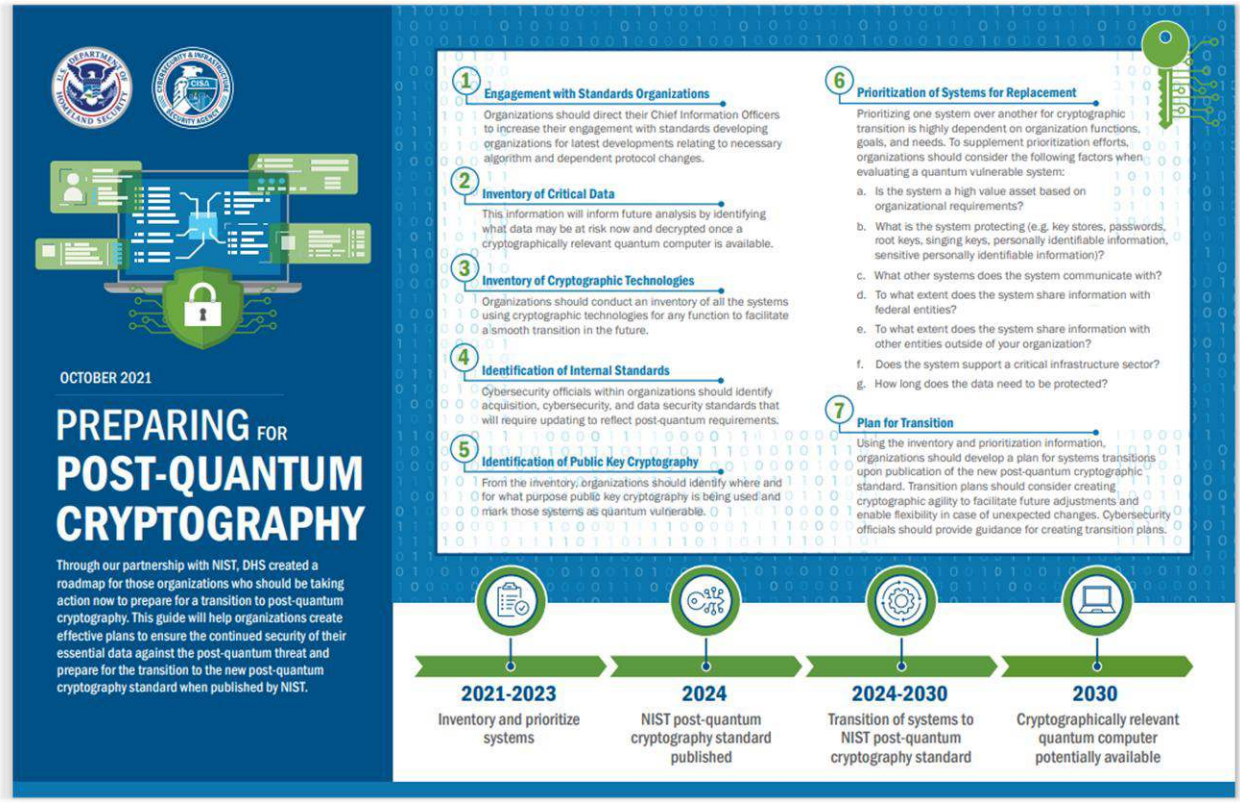
[2] https://www.nist.gov/news-events/news/2024/10/nist-announces-14-candidates-advance-second-round-additional-digital

© ASC X9 Inc., 2025 – All Rights Reserved

This paper concludes by calling for the financial industry and government agencies to act now to prepare for the migration to PQC. The sooner planning begins, the more time there will be to mitigate risks and ensure a smooth, efficient transition to PQC.

NOTE: Regarding due diligence, we recognize that no *required* sequence or industry assessment for a cryptographic migration exists, for if we had such a proven list, we would use it.

As a point of reference and a good starting point, the US Department of Homeland Security[3] has documented some of the actions agencies and organizations should take to prepare for PQC.



3 Scope

This document provides general information and background for creating plans to migrate a company's, organization's, or agency's pre-quantum cryptographic infrastructure to a post-quantum cryptographic infrastructure that, at a minimum, has significant resistance to quantum attacks or is considered secure against them. A migration of this nature is complex, but it can be managed through software tools, detailed planning, and adherence to standards. The use of standards will mitigate the risks associated with the use of new technologies and provide guidance that includes best practices. Software tools can help reduce the overhead required to identify problems across an organization, as well as plan and track corrective actions.

Some of the areas addressed in the paper include:

[3] "Preparing for Post-Quantum Cryptography: Infographic", US Department of Homeland Security - https://www.dhs.gov/publication/preparing-post-quantum-cryptography-infographic

© ASC X9 Inc., 2025 – All Rights Reserved

- Crypto Policy Management
  - Need for automated tools to manage the cryptographic life cycle, including inventory management, enforceable cryptography policy, and agile selection of cryptography services
- Design Tradeoffs
  - Need for practical approaches to maintaining current cryptographic protections while smoothly transitioning to PQC
- Implementations and Interoperability
  - Need current cryptography systems and services to co-exist that are interoperable
- Compliance Assurance
  - Need standards-compliant, certified, and documented replacement cryptography products we can rely upon to protect business operations in hybrid and multi-cloud environments
- Deployment Guidelines
  - Need a reference architecture for migration to guide a long transition period

4 Data Value and Lifecycle

When prioritizing cryptographic assets in the financial industry for protection against quantum attacks, it is essential to consider the value and criticality of the data they safeguard. The financial industry deals with a vast amount of sensitive information, and not all data elements have the same level of importance.

4.1 Determining Data Value

Here are some steps to determine the value of data that needs protection from a quantum attack:

1. **Data Classification**: Classify the data based on its sensitivity or importance. Categorize data into levels such as public, internal, confidential, personally identifiable information (PII), financial transactions, cryptographic keys, and other critical assets.
2. **Financial Impact Analysis**: Assess the potential financial impact of a data breach or compromise for each category. Consider losses, liabilities, regulatory fines, and the erosion of customer trust.
3. **Regulatory Compliance**: Consider regulatory requirements specific to the financial industry. Identify data elements governed by regulations such as PCI DSS, GDPR, GLBA, or local financial data protection laws. Prioritize protection for data that must comply with these regulations.
4. **Business Continuity Dependence**: Evaluate how the data supports business continuity and the smooth operation of financial systems. Prioritize data that is crucial for uninterrupted business processes.
5. **Trade Secrets and Intellectual Property**: Identify data that constitutes trade secrets, intellectual property, or proprietary financial models. Such data is critical to maintaining a competitive edge and should be given high priority for protection.
6. **Data Usage and Access**: Analyze the frequency of data usage and the number of users who have access to each data category. Data that is frequently accessed or widely distributed may require stronger protection measures.
7. **Interconnectedness and Dependencies**: Understand how different data elements are interconnected and their dependencies on one another. Prioritize protecting data that could serve as a gateway to accessing other sensitive information.

© ASC X9 Inc., 2025 – All Rights Reserved

8. **Quantum Vulnerability**: Evaluate the susceptibility of different data elements to quantum attacks. Data vulnerable to “harvest now, decrypt later” attacks should be prioritized for quantum-safe protection.
9. **Customer and Stakeholder Trust**: Consider the impact of a data breach on customer and stakeholder trust. Protecting data that directly affects client trust is crucial for maintaining a positive reputation.
10. **Cost-Benefit Analysis**: Conduct a cost-benefit analysis to evaluate the resources needed to implement quantum-safe protection for each data category. Balance the potential impact of a quantum attack against the investment needed for protection.

By following these steps, financial institutions can effectively prioritize inventory items for protection from a quantum attack. The goal is to focus resources on securing the most critical and sensitive data, ensuring resilience against emerging quantum computing threats while complying with regulatory requirements and maintaining the trust of customers and stakeholders.

4.2 How Long Does the Data Require Protection?

The required protection lifespan of data significantly influences an organization’s PQC migration strategy. Sensitive data requiring long-term protection is more vulnerable to “harvest now, decrypt later” attacks than short-lived data and should therefore be prioritized in the post-quantum migration process. The duration for which data must be protected depends on a variety of legal, regulatory, business, and security factors. Key factors influencing data protection timelines include:

1. **Data Retention Policies**: Organizations must adhere to data retention policies mandated by laws and regulations specific to their industry. These policies outline the minimum and maximum duration for which certain types of data must be retained for compliance purposes.
2. **Data Classification**: Different data categories have varying retention requirements based on their sensitivity and criticality. Highly sensitive data may require longer protection periods compared to less critical information.
3. **Legal and Regulatory Requirements**: Laws and regulations may specify specific retention periods for different types of data. For example, financial institutions may need to retain transaction records for a certain number of years to comply with financial reporting standards.
4. **Contractual Obligations**: Agreements with customers, partners, or service providers may specify how long certain data must be retained and protected.
5. **Statute of Limitations**: In legal matters, the statute of limitations determines the maximum period during which legal actions can be initiated based on specific events. Data related to potential legal disputes may need to be retained until the statute of limitations expires.
6. **Business Necessity**: Some data may be required for ongoing business operations or historical analysis. Organizations may retain data for as long as it is deemed necessary to support business activities or decision-making processes.
7. **Security Considerations**: Data sensitivity and exposure risk often determine how long protection must be maintained. Highly sensitive data typically requires extended retention.
8. **Data Lifecycle Management**: Data lifecycle management practices may influence the retention period. Organizations may determine specific stages for data retention, archival, and disposal based on the data's age and relevance.
9. **Customer Consent**: Retention timelines may be governed by customer consent agreements, which can define how long data may be stored.

© ASC X9 Inc., 2025 – All Rights Reserved

10. **Data Privacy Regulations**: Privacy regulations, such as GDPR, may impose limitations on data retention and require the erasure of personal data after a certain period, once the purpose for which it was collected has been fulfilled.

It is essential for organizations to have well-defined data retention and protection policies that consider these various issues. By understanding and adhering to legal requirements, industry standards, and best practices, organizations can effectively manage data retention and protection to ensure data security and compliance with applicable regulations.

5 Cryptographic Audit and Inventory

As part of an organization's cryptographic readiness analysis, it is important to establish policies and procedures for conducting an organization-wide cryptographic audit and inventory.

Many organizations are now facing the reality that they lack a clear and comprehensive understanding of their cryptographic footprint—both for data in motion and data at rest.

The Key Components of an organizational wide Cryptographic Audit and Inventory include:

1. Cryptographic inventory, including
    a. Data Delivery Channels for Data in Transit
    b. 3rd Parties, Contractors, and Suppliers
2. Cryptographic Risk Assessment

This challenge is compounded by the reliance on open-source and third-party software and systems, and by the technical debt accumulated from decades of complex hardware, software, and cloud infrastructure.

As organizations adopt Zero Trust environments across converging IT, OT, and IoT systems—including on-premises, off-premises, and cloud-based deployments—they must develop a comprehensive understanding of their cryptographic footprint. The criticality of gaining a firm understanding of the entire Cryptographic footprint is not only desired but required to properly safeguard organizations both today and for the future.

This problem is faced by all Organizations globally and will be a critical hurdle that will need to be addressed as Organizations go through their PQC migration process. It is important to note that, like most audits, this will be a lengthy, expensive, and time-consuming process—and not one that can be easily addressed through AI or automation alone.

Audits, especially when performed for the first time are extremely labor intensive and require a wide array of skills and a large team to do it properly such that the results are both useful and exhaustive.

Despite the uncertainty about when a cryptographically relevant quantum computer will be able to break current encryption standards, properly inventorying all cryptographic assets in use is the essential first step in PQC migration preparedness—and it is a "today" problem that financial institutions must begin addressing, regardless of how they plan to approach the migration.

© ASC X9 Inc., 2025 – All Rights Reserved

The reality is that an organization cannot begin planning a large digital transformation project—such as a PQC migration—without first understanding the cryptographic assets currently in use across the enterprise.

Through the adoption of best practices and policies and procedures around creating an organizational wide Crypto System of Record, and beginning to implement CBOM's organizations can properly begin to discover, inventory, catalogue and manage their organization's cryptographic footprint.

5.1 Cryptographic Inventory

A critical component of cryptographic lifecycle management is maintaining an up-to-date cryptographic product inventory. Such an inventory should include information about:

1. Software products related to cryptography (procured or developed in-house);
2. Vendors that provide a cryptographic product or service;
3. Algorithms used including name, purpose and parameters used to operate;
4. The location of static cryptographic keys, both private and public;
5. Internal or third-party organization responsible for deployment and maintenance;
6. Protocols being used including configurations; and
7. Any information relevant to the management of cryptography within the organization.

By creating a cryptographic asset and product inventory—along with a list of the organization's most sensitive and critical data assets requiring extended security—organizations can conduct more effective risk analysis. This approach helps us identify vulnerable data, systems, and processes, safeguarding them against potential breaches.

The level of effort required to fully inventory and understand an organization's vulnerability to a quantum-enabled threat actor is a function of the size and complexity of its enterprise network and computing assets. This level of understanding can support not only the implementation of PQC, but also the broader management and operation of the organization's security infrastructure. Other benefits include recovery from disasters, security compromises, as well as facilitate high availability.

As organizations conduct enterprise-wide cryptographic audits, they should also generate Cryptography Bills of Materials (CBOMs)—structured inventories that catalog the cryptographic components in a system, including algorithms, key types, libraries, protocols, and usage contexts for legacy systems. Legacy systems are often the largest contributors to cryptographic technical debt. These systems frequently rely on outdated algorithms, hardcoded keys, or undocumented libraries, making them difficult to assess and remediate without visibility. Creating legacy CBOMs enables targeted remediation of these weaknesses and supports more accurate tracking of inherited technical debt. In addition, organizations may choose to share CBOM data with vendors or partners using similar legacy systems—promoting a coordinated approach to reducing technical debt and strengthening the overall security posture across shared environments.

5.1.1 Stored Corporate Assets

When assessing corporate assets for updates in a post-quantum world, be sure to include devices and software that store passwords, cryptographic keys, certificates, or any other artifacts used to secure your IT infrastructure. These devices should use some sort of cryptography to protect the assets stored in them. Therefore, it is critical to assess these algorithms to determine whether they need to be updated to PQC-certified versions. Updating software products or physical devices will, in most cases, require updating software. Some physical devices might have to be replaced with updated devices. The following subsections describe only a few examples of assets used to store cryptographic data.

© ASC X9 Inc., 2025 – All Rights Reserved

5.1.1.1 Digital Wallet/Vault

Some employees may be authorized to store or transport sensitive information, such as cryptographic keys, access codes, financial account data, identification information, and more. This information may be stored in portable devices know as a digital wallet or sometimes a digital vault. The information stored on the device can be transferred to a receiving device, for example, by near-field communication (NFC), Bluetooth, wi-fi, or cellular technologies. These devices generally rely on cryptography to securely store and transmit data. Many software and device vendors provide these types of devices.

Some IT administrators and field service personnel may use a digital wallet to store cryptographic information critical to your IT infrastructure such as FIDO2 passkeys. Therefore, these devices must be considered in a plan to upgrade to PQC. Transitioning these devices to PQC algorithms will likely require a vendor-provided upgrade or replacement, along with reloading credentials or data encrypted using PQC-based keys.

Note: Some devices that run a digital wallet may have insufficient computing power, storage, or other capabilities needed to support PQC thereby necessitating an upgrade or replacement of the device.

5.1.1.2 Password Safe or Key Safe (software)

This software is similar to a digital vault but has a more limited purpose: it is designed to store account names along with their associated passwords and keys used for software or network functions. This software is used by IT personnel to gain access or to update software that is part of your IT infrastructure. This type of product must be included on any list of cryptographic assets to be reviewed for PQC support.

Password vaults are software tools to safely store user passwords, basically to avoid users writing passwords on sticky notes. Users might have different passwords for each application, different passwords for each role to enforce separation of duties between regular versus administrative access, or difference passwords for each environment to enforce separation between production and lower environments such as development or testing environments.

Password vaults might be a local application running on an individual's workstation, an enterprise-wide central service, or a combination of both. Some vaults protect passwords using unique encryption keys per user and protect the encryption keys using asymmetric cryptography. These vaults also use PKI to secure password transfers, and therefore must be upgraded to support PQC algorithms.

5.1.1.3 PKI Certificates

PKI (Public Key Infrastructure) is a system used to create, manage, distribute, and use digital certificates to protect data. It is based on public/private key cryptography. It is the general accepted belief that future quantum computers will be able to break current algorithm used by PKI systems with minimal effort. PKI certificates are used to provide trust services such as protecting data and for authentication in activities in e-commerce and banking. For example, web browsers use PKI to establish secure HTTPS connections for accepting credit card information and conducting online banking. Automatic Teller Machines (ATMs) use PKI to communicate securely with bank servers to approve transactions. As you can see, PKI is a fundamental building block of secure communications. Therefore, it is critical that any use of PKI is identified and included in a cryptographic inventory as they will need to be upgraded to quantum safe algorithms.

© ASC X9 Inc., 2025 – All Rights Reserved

5.1.2 Data Delivery Channels for Data in Transit

Data delivery channels are the mechanisms through which data is transmitted, shared, and accessed both within and between organizations. As quantum computing advances, traditional data delivery channels may become increasingly vulnerable to quantum-enabled attacks. To mitigate these risks, organizations should include data delivery channels in their cryptographic audit and inventory, then consider strengthening the following areas:

1. **Quantum-Safe Encryption Protocols**: Implement encryption protocols that are resistant to quantum attacks and ensure the confidentiality and integrity of data in transit.
2. **Post-Quantum Key Establishment**: Use post-quantum key exchange methods to securely establish communication channels. Quantum-resistant key establishment ensures that cryptographic keys remain protected from quantum attacks.
3. **Authentication Mechanisms**: Assess and update authentication mechanisms used in data delivery channels. Multi-factor authentication and quantum-safe authentication methods should be adopted to prevent unauthorized access to sensitive data.
4. **Quantum-Safe VPN and Tunnels**: For secure communication between different entities, consider quantum-safe Virtual Private Networks (VPNs) and tunnels. These solutions protect data as it traverses potentially untrusted networks.
5. **Integrity and Data Validation**: Implement measures to ensure the integrity and validation of data in transit. Techniques like digital signatures and message authentication codes (MACs) can help detect and prevent data tampering.
6. **Quantum-Resistant Access Controls**: Strengthen access controls to prevent unauthorized access, ensuring that permissions are properly assigned, enforced, and monitored.
7. **Crypto-Agility for Channel Updates**: Plan for crypto-agility in data delivery channels, enabling the swift adoption of new cryptographic methods when quantum-safe standards emerge. This ensures a proactive response to quantum threats.
8. **Regular Security Audits**: Conduct regular security audits and assessments of data delivery channels to identify potential vulnerabilities and weaknesses. Address any issues promptly to enhance the overall security posture.
9. **End-to-End Encryption**: Encourage the use of end-to-end encryption for sensitive data in data delivery channels. This ensures that data remains encrypted and secure throughout its entire journey.
10. **Employee Awareness and Training**: Promote best practices and data security through targeted training programs that address risks in data delivery channels. Educate personnel about the risks associated with quantum threats and the measures in place to protect data.
11. **Third-Party Vendor Assessments**: If data delivery channels involve third-party vendors or service providers, assess their readiness for post-quantum cryptography and ensure they adhere to robust security standards.

By addressing issues related to data delivery channels and implementing these measures as appropriate, organizations can build a resilient and quantum-safe data communication infrastructure. Securing data during transmission and storage is essential to safeguarding the confidentiality, integrity, and availability of sensitive information in the face of emerging quantum threats. A comprehensive approach to data delivery channels ensures that data remains protected and organizations can continue to operate securely in the post-quantum era.

© ASC X9 Inc., 2025 – All Rights Reserved

5.1.3 Third Parties, Contractors, and Suppliers

Financial institutions must adopt a systematic, comprehensive approach to ensure post-quantum cryptography readiness among third-party contractors and suppliers. Because these external entities often handle sensitive data, it is crucial to include 3rd parties in the cryptographic audit and inventory, and to ensure they adhere to required security standards.

Here are some steps a financial institution can take to deal with third-party contractors and suppliers in relation to post-quantum cryptography:

1. **Vendor Selection and Due Diligence**: Prioritize vendors with a strong track record in data security and readiness for post-quantum cryptography. Conduct thorough due diligence to evaluate their current practices.
2. **Contractual Obligations**: Incorporate specific clauses and requirements related to post-quantum cryptography readiness into contracts with third-party contractors and suppliers. Clearly outline the need for compliance with post-quantum cryptographic standards and data protection measures.
3. **Education and Awareness**: Ensure third-party partners understand the importance of post-quantum cryptography and its implications for securing sensitive data.
4. **Assessment of Security Measures**: Request detailed information from third-party contractors and suppliers regarding their current security measures, encryption methods, and key management practices. Evaluate their readiness for post-quantum cryptography and assess their ability to protect data against quantum computing threats.
5. **Post-Quantum Cryptography Integration Plan**: Work collaboratively with third-party contractors and suppliers to develop a plan for integrating post-quantum cryptographic solutions into their systems and services. Set clear timelines and milestones for implementation.
6. **Testing and Validation**: Conduct joint testing and validation of post-quantum cryptographic solutions in the systems of third-party contractors and suppliers. Ensure that the implementations are secure, performant, and compatible with the financial institution's requirements.
7. **Ongoing Monitoring and Auditing**: Establish ongoing monitoring mechanisms to assess the compliance of third-party contractors and suppliers with post-quantum cryptography readiness. Conduct regular audits to verify their adherence to security practices and data protection standards.
8. **Data Privacy and Sharing**: Ensure that data sharing and access mechanisms with third-party contractors and suppliers are designed to protect the confidentiality and integrity of financial data. Enforce strict data privacy controls to mitigate risks associated with shared information.
9. **Incident Response and Reporting**: Collaborate with third-party contractors and suppliers to develop incident response plans that address potential security breaches and data incidents related to post-quantum cryptography. Establish clear reporting procedures in case of security breaches.
10. **Continual Improvement**: Foster a culture of continual improvement in data security practices with third-party contractors and suppliers. Encourage regular updates to cryptographic methods and best practices to stay ahead of evolving threats.

By following these steps, the financial institution can ensure a cohesive and secure approach to post-quantum cryptography readiness with third-party contractors and suppliers. Collaboration and proactive engagement with external entities are essential to establish a unified front in protecting sensitive financial data from quantum-enabled threats across the entire ecosystem.

© ASC X9 Inc., 2025 – All Rights Reserved

5.2 Cryptographic Risk Assessment

Before undertaking a migration to post-quantum cryptography (PQC), organizations must understand not just what cryptographic assets they use, but also which assets are most critical and why. This involves identifying the data, systems, and cryptographic components that are most at risk from quantum-enabled threats. The prioritization process must be guided by an awareness of cryptographic dependencies, key hierarchies, data classification, and external partnerships. This section outlines key considerations that can help financial institutions evaluate their cryptographic landscape with precision—enabling smarter prioritization, targeted remediation, and more resilient long-term planning.

- **Understanding Dependencies and Cryptographic Key Hierarchies**: When prioritizing inventory items for data protection, it is essential to identify those that warrant the highest level of attention. This entails a comprehensive examination of how various data elements, systems, and processes interrelate, particularly in the context of encryption and cryptographic key management.
- **Data Dependencies and Priority**: Begin by mapping out data dependencies and determining their priority. Identify which data sets are not only reliant on others for functionality or business processes but also which ones, if compromised, would have the most severe impact. For example, financial transaction records might depend on customer account data, and the loss of encryption keys protecting this data could have cascading effects on the entire financial ecosystem. These high-priority data elements should be at the forefront of protection efforts.
- **Cryptographic Key Hierarchies and Priority:** Equally critical is the understanding of cryptographic key hierarchies and how they align with data priority. Modern security practices often use hierarchical key structures, where distinct keys protect different layers of data. Identify root keys within these hierarchies and prioritize their protection. Compromising a root key can expose all data within its hierarchy, making these keys of the utmost priority in the protection strategy.
- **Understanding External Dependencies:** In addition to internal dependencies, it is critical to assess external dependencies when prioritizing cryptographic protection efforts. Organizations in the financial industry often rely on external entities such as contractors, suppliers, and service providers to fulfill various aspects of their operations.
- **Contractor Obligations and Priority**: Consider, for instance, the role of contractors in the supply chain. Contractors handling or processing sensitive data must meet defined obligations for security and compliance. Prioritize the protection of data entrusted to external partners based on its criticality, ensuring that data with the highest priority receives the most stringent protection measures.
- **External Company Dependencies and Priority:** Moreover, your organization should acknowledge that it could be reliant on external companies for critical components of a comprehensive data protection solution. This may encompass cloud service providers, security software vendors, or consulting firms specializing in cybersecurity. The effectiveness of these external relationships directly impacts the organization's overall security posture. Prioritize the evaluation and continuous monitoring of external partners' security measures, giving higher priority to those whose services involve the most critical data.

By understanding and prioritizing both internal and external dependencies, organizations in the financial industry can make informed decisions about where to allocate resources for data protection. This approach ensures that the highest-priority items, which, if compromised, would have the most significant impact on the organization, receive the utmost attention and protection measures, fortifying their security posture and resilience.

© ASC X9 Inc., 2025 – All Rights Reserved

6 Building A Migration Plan

As quantum computing continues to evolve, organizations must urgently update their cybersecurity and data security policies, standards, procedures, and practices to mitigate the unique risks posed by quantum computing. This process ensures that cryptographic methods and associated policies remain resilient in the face of emerging quantum threats. The steps below illustrate how to update existing standards and procedures to integrate post-quantum cryptography (PQC) requirements. These steps serve as a general guide for organizations to evaluate and replace outdated standards with PQC-compliant alternatives, though the specifics will depend on each organization's needs.

1. **Threat Assessment**: Start with an in-depth analysis of the risks posed by quantum computing to your current infrastructure. This assessment should be integrated into your ongoing risk management framework and will help identify systems most vulnerable to quantum threats, illustrating the need for PQC solutions to maintain robust data protection and business continuity.
2. **Cryptographic Policy Review**: Conduct a comprehensive review of your organization's cryptographic policies to identify not only vulnerable algorithms but also any gaps in governance, compliance, and lifecycle management practices that could be exposed to quantum threats. Ensure that your policies incorporate robust guidelines for the adoption of post-quantum cryptographic algorithms and an agile approach to future updates.
3. **Standard Evaluation**: Assess the cryptographic standards currently implemented across systems and evaluate their effectiveness against quantum attacks. Prioritize standards that require revision or replacement with PQC alternatives, considering not only technical resilience but also financial and operational impacts to ensure a cost-effective, sustainable migration.
4. **Procedure and Practice Analysis**: Review cryptographic procedures and practices, such as key management, certificate issuance, and authentication mechanisms. Identify areas that will need modification to accommodate post-quantum cryptographic requirements.
5. **Post-Quantum Cryptography Adoption Plan**: Formulate a strategic, phased adoption plan for integrating PQC standards. This plan should outline the timeline for implementation, potential challenges, resource requirements, and a clear strategy for aligning with business processes and long-term goals to ensure a smooth, efficient transition.
6. **Vendor and Third-Party Engagement**: Proactively engage with vendors and third-party service providers to assess their readiness for offering PQC solutions. Develop long-term collaborative relationships with external providers to ensure their products and services remain compliant with evolving post-quantum standards and continue to align with your organization's security strategy.
7. **Employee Training**: Establish role-based training programs to ensure that all relevant employees—from system administrators to executives—are aware of the significance of post-quantum cryptography. Training should include:
    1. Hands-on workshops on the application of post-quantum algorithms and their integration with existing systems.
    2. Executive briefings to understand strategic impacts and investments required for PQC adoption.
    3. Cybersecurity training focusing on the unique risks quantum computing poses to cryptography and security operations.
    4. Ongoing refresher courses as new PQC standards evolve and are integrated into the organization's security architecture.

© ASC X9 Inc., 2025 – All Rights Reserved

8. **Testing and Validation**: Implement rigorous testing and validation protocols for all post-quantum cryptographic solutions to ensure they:
    1. Meet established security standards and regulatory requirements.
    2. Do not introduce vulnerabilities, ensuring that post-quantum cryptography is thoroughly vetted against potential attack vectors.
    3. Perform operationally without significant performance degradation, ensuring that systems can handle increased computational load or latency issues.
    4. Integrate seamlessly with existing cryptographic systems in hybrid environments (e.g., legacy and PQC systems co-existing).
    5. Include user acceptance testing (UAT) and involve end users in testing the operational readiness of the systems.
    6. Include performance benchmarking to ensure that PQC integration does not negatively impact critical workflows.
9. **Implementation and Compliance**: Adopt a phased implementation strategy for the migration to post-quantum cryptography. The strategy should:
    1. Prioritize high-risk systems for early adoption of PQC.
    2. Establish compliance checkpoints to ensure that each phase meets regulatory and industry standards.
    3. Monitor integration progress continuously and adjust the approach based on lessons learned from earlier implementations.
    4. Implement cross-departmental oversight, involving security, compliance, and technical teams in compliance verification.
    5. Develop clear documentation for compliance reporting and audit purposes.
10. **Continuous Monitoring and Review**: Establish a real-time monitoring framework to continuously evaluate the effectiveness and security of post-quantum cryptographic solutions. This should include:
    1. Automated security alerts for any cryptographic weaknesses or breaches.
    2. Regular audits (quarterly or biannually) to assess the cryptographic infrastructure's readiness against emerging quantum threats.
    3. Data-driven reviews using threat intelligence feeds to stay up to date on the latest quantum computing advancements.
    4. Policy review cycles to ensure that cryptographic practices evolve as new PQC algorithms and attack vectors are identified.

By following this structured process, organizations can begin mitigating the cryptographic risks posed by quantum computing and transition toward standards that incorporate post-quantum requirements. This forward-leaning approach strengthens the organization's overall security posture and enhances the long-term protection of sensitive data in an evolving threat landscape.

6.1 Remediation Best Practices

Once a cryptographic audit and inventory have begun, a parallel effort can be launched to develop the organization's remediation and migration strategy. This includes establishing the necessary budgets, timelines, and workflows to secure the organization in a post-quantum environment and to guide the PQC migration process.

Organizations can work to overlay the results from their findings in the Cryptographic Audit and Inventory process as outlined above to help prioritize and triage the remediation lifecycle.

© ASC X9 Inc., 2025 – All Rights Reserved

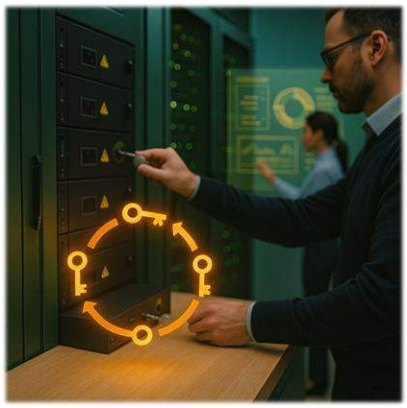
Depending on the type of organization, some infrastructure may become PQC-compliant automatically—provided that libraries and critical code are updated. It will be critical for organizations to work with their external key stakeholders (vendors, clients, supply chain, and independent compliance organizations and standards bodies) to ensure that critical items are being remediated in a timely fashion and nothing is “taken for granted”.

Important migration challenges include:

1. cryptographic technical debt embedded in mission-critical legacy systems that often form the core of the financial services industry.
    a. In a lot of instances, those systems cannot just be removed or upgraded without extensive testing and evaluation. Organizations must develop plans, conduct research, implement monitoring tools to track interconnected systems, and establish policies for decommissioning and transitioning legacy systems—with rollback procedures in place in case of failure.
    b. If not properly managed migration failures could create global systemic risks due to the interconnected reliance that is found among the financial services industry. The common assumption and best practices is that these legacy systems will need to be replaced and new systems finally installed. While conceptually sound, some of these systems are so complex it will take years to fully understand all of the various parts and pieces that will be affected by those changes.
2. Capability of legacy systems and edge-based hardware and software to do the more complex math required by the post quantum encryption algorithms and longer key sizes.
    a. In some instances the cryptographic process is actually performed on the silica or chips of embedded devices and systems and despite a desire to push an upgrade, it is impossible for the device to actually perform the new complex calculations of the PQC algorithms without having an adverse effect on quality of service.

This is where the majority of resources, budgets, and expertise will need to be focused. As these issues will not remediate themselves and will require organizational wide support and key stakeholder buy in to properly go through the upgrade cycle.

6.2 Cryptography Life Cycle Management



As cryptographic products age, threat actors continue to develop more sophisticated attack methods capable of exploiting outdated or weakened algorithms. To maintain a strong security posture, it becomes essential to regularly update and manage cryptographic systems across the enterprise. Allowing cryptographic tools and libraries to operate without consistent maintenance or modernization introduces what is commonly referred to as “cryptographic technical debt”—a buildup of security risks and operational inefficiencies caused by legacy algorithms, expired certificates, or unsupported modules. This form of technical debt not only increases an organization’s exposure to compromise but can also create compliance challenges, limit interoperability with modern systems, and increase the cost and complexity of future migrations. Proactive cryptographic life cycle management helps mitigate this risk by ensuring cryptographic assets evolve in step with emerging threats, evolving standards, and regulatory expectations.

One of the challenges with cryptographic technical debt is that it often remains invisible until it causes a failure—such as a broken integration, an expired certificate, or an exploit of a known algorithmic weakness. These risks accumulate quietly over time and may not be adequately accounted for in traditional vulnerability assessments. As advancements in computing power, cryptanalysis, and quantum research accelerate, the risks posed by outdated

© ASC X9 Inc., 2025 – All Rights Reserved

cryptographic components grow significantly. Without early detection and remediation, technical debt can quickly become a systemic weakness that undermines an organization's broader security and compliance posture.

To effectively manage cryptographic technical debt, organizations should implement a cryptographically agile architecture—one designed to support rapid, low-risk updates to cryptographic algorithms, libraries, and protocols. This agility enables teams to remediate vulnerabilities quickly, integrate post-quantum cryptographic standards as they become available, and maintain compliance with evolving regulatory requirements. By decoupling cryptographic functions from application logic and infrastructure, crypto-agile systems reduce the operational burden of change and help future-proof security investments against emerging threats.

A cryptographically agile architecture empowers organizations to respond swiftly to emerging vulnerabilities while maintaining a proactive approach to security planning. This dual capability minimizes exposure to known exploits, supports rapid patching or algorithm updates, and ensures continuity of operations—even during cryptographic transitions. Regular updates enabled by agile infrastructure reduce the risks associated with aging cryptographic components, help meet regulatory demands, and safeguard sensitive data against both current and future threats.

To improve visibility and reduce cryptographic technical debt, organizations should automate CBOM generation, which ensures that every time cryptographic functionality is introduced into a product or system, a corresponding record is created and maintained. Dynamically updated CBOMs can be integrated into development pipelines, and shared with relevant stakeholders to support audits, risk assessments, and compliance reporting.

The following is a summary of cryptography life cycle management considerations.

1. Awareness and Risk Assessment
2. Implementing Cryptographically Agile Architectures
3. Managing Cryptographic Technical Debt
4. Automating Cryptographic Asset Tracking with CBOMs
5. Enhancing Security with Maturity Models

Effectively managing the cryptographic life cycle is essential to minimizing risk, reducing technical debt, and ensuring long-term resilience in a rapidly evolving threat landscape. By adopting crypto-agile architectures, maintaining up-to-date inventories through automated CBOMs, and integrating lifecycle oversight into regular audits and policy enforcement, organizations can stay ahead of both classical and quantum-era threats. These practices not only support operational continuity and compliance but also lay the groundwork for scalable, secure cryptographic systems that can adapt as new standards and technologies emerge.

6.2.1 Cryptographically Agile Architectures

Cryptographic agility and cryptographically agile architectures do not yet have universally accepted industry definitions. These are high-level concepts currently being explored by many organizations and industry groups. Nevertheless, there is a growing consensus that they will be essential for building and maintaining quantum-safe information systems. More broadly, these concepts are expected to become integral design requirements for future systems. Completely defining either of these concepts is outside the scope of this document. However, below are some potential characteristics of crypto agility and of crypto agile architectures, and of how they might be adopted in enterprise environments.

© ASC X9 Inc., 2025 – All Rights Reserved

Repeatable	Flexible	Reactive	Nimble
Able to change its cryptographic systems and processes as needed without compromising consistency, speed, or the ease of future changes.	Able to support multiple crypto protocols and primitives with the freedom to switch back and forth as desired.	Has the speed and flexibility to change course in response to new cryptographic security incidents and threats.	Able to adopt new technology faster, with reduced operational risk, while increasing competitive advantage.

Table 1: Example Features of a Cryptographically Agile Architecture

Cryptographic agility is an attribute of an information system that anticipates future requirements to change the cryptographic algorithms and primitives used by that system. A cryptographically agile system is able to have the cryptography it uses be dynamically changed with minimal impact to the system's functionality or availability. By introducing crypto agility, the costs and impacts of future changes to a system can be greatly reduced.

While crypto agility is an attribute of a specific information system, a cryptographically agile architecture refers to the architectural design of a collection of cryptographically agile systems and of how cryptography is managed within and between those systems. The main purpose of a crypto agile architecture is to orchestrate security protocols and algorithms among the constituent systems while maintaining interoperability and workflows among those systems. Additionally, these changes should be done such that the impacts to dependent systems and processes are minimized. A cryptographically agile architecture enables administrators to fully utilize the crypto agility of the individual systems.

A crypto agile architecture can be used to provision quantum-safe encryption for data (at rest or in transit) throughout an IT environment without significantly impacting the operation of the systems in that environment. In contrast, even if a given system has the cryptographically agile attribute, there still needs to be a mechanism to control any cryptographic changes. Given a collection of crypto agile systems, networked together, administrators will need some way to orchestrate cryptographic changes among the systems, again while ensuring their continued interoperability and operation. Ideally, this is achieved through a well-designed cryptographically agile architecture.

The following considers how cryptographically agile architectures might be built and deployed in the future.

It is common for maturity models to be defined for implementations of design concepts. That is, different implementations of a framework or a design philosophy can have different levels of capabilities, where those levels are rigorously defined. Levels can range from immature, low-capability implementations to highly-mature, fully functional, optimized implementations. Examples include: Stages in CISA's Zero Trust Maturity Model v2.0, Implementation Tiers for the NIST Cybersecurity Framework v2.0, Capability Levels for COBIT 2019 processes, or even FIPS 140-3 Security Levels and Common Criteria Evaluation Assurance Levels.

These levels are useful to organizations for several reasons—primarily because they provide a structured, step-by-step approach to improving systems over time. It is not usually reasonable for an information system to undergo a transformation from low capability to high capability in one step. In practice, such improvements are usually done over time in an intentional and tightly controlled manner. Secondly, as not all systems require a fully capable

© ASC X9 Inc., 2025 – All Rights Reserved

implementation of a given framework, these levels help organizations identify the appropriate target maturity levels for their needs.

Given the above, it is reasonable to assume that in the near future a maturity model will be defined for cryptographically agile architectures. That is, real world implementations of the architecture can have a defined range of capabilities or maturity levels. Ranging from only offering the most basic form of crypto agility to being a complete architecture, possibly able to automatically manage cryptographic policies, dynamically change system configurations, apply patches, switch out algorithms, cryptographic primitives, protocols and software libraries, perform key management, certificate lifecycle management, vulnerability and risk assessments, and so on.

It is also reasonable to suggest that a fully mature cryptographically agile architecture will require the introduction of an abstracted cryptographic layer into the architecture design. Instead of embedding cryptography within physical systems or tightly coupling it with protocol implementations, it can be abstracted into its own layer and modified via API calls. Moreover, given the broad range of capabilities a fully-mature crypto agile architecture might one day have, it is sensible to predict that the architecture will heavily leverage many of the existing risk and change management processes and procedures organizations already use. Notably, and especially for large organizations, one would expect the evolution to a fully mature cryptographically agile architecture to take a decade or longer to achieve.

For readiness assessment, consider:

1. (inventory phase) to what extent does your organization implement a cryptographically agile architecture?
    a. Consider an industry-derived or custom maturity model as an evaluation tool
2. (planning) Does the maturity of the cryptographic architecture meet the needs of the organization as they consider PQC adaptation?
    a. Scope, design & plan for any needed work to improve the maturity of the architecture
3. (implementation) Consider industry best practices and partner dependencies/interfaces as you enhance the maturity of your cryptographic architecture

6.2.2 Cryptography Bill of Materials (CBOM)

CBOMs allow organizations to track and share detailed information about cryptographic assets—both internally and externally—across tools, development kits, software suites, systems, and technologies deployed within the organization or provided to customers, partners, vendors, and clients. CBOMs can be generated to support all IT, OT, and IoT infrastructures, including—but not limited to—hardware systems, embedded systems, Enterprise Resource Planning (ERP) systems, mobile applications, virtual appliances, and cloud environments.

Not only do CBOMs contain technical information about the cryptography in use (e.g., key strengths, algorithm parameters, primitives, certificate data, protocol version and configuration data, and so on), they also track dependency information. Knowing cryptographic dependencies is crucial for planning vulnerability remediations or cryptographic migrations.[4]

CBOMs help organizations quickly identify and track remediation requirements when tools are deprecated or modified. They also serve as valuable resources for managing cryptographic technical debt. CBOMs can either be a standalone item or can be included as a subcomponent of a larger, more general, Bill of Materials (BOM). For example, the recent CycloneDX v1.6 specification allows CBOM information to be embedded into a Software Bill of Materials (SBOM) or a Hardware Bill of Materials (HBOM)[5].

[4] OWASP (Open Web Application Security Project) is developing best practices and templates.

[5] CycloneDX Cryptography Bill Of Materials Capabilities: https://cyclonedx.org/capabilities/cbom/

© ASC X9 Inc., 2025 – All Rights Reserved

As organizations pursue crypto agility and interoperability for both data in transit and at rest, it is essential to develop policies, procedures, and systems that automatically update and distribute CBOMs to all stakeholders in real time.

6.3 Crypto Asset Management

Cryptography is ubiquitous in modern business organizations and may be embedded in any form of digital information technology. When it works as designed, it is typically not obtrusive and we are frequently unaware of its presence when conducting everyday business.

Like many IT products, cryptographic products (hardware, software and supporting libraries) have a product lifecycle that requires periodic updates to maintain functionality and security as well as provide for product improvements and to maintain interoperability. To keep pace with the cryptographic product lifecycle, it is necessary to keep track of vendors, products (major and minor versions), placement within your IT infrastructure and hosting environment, and the criticality of the cryptographic functions that may impact your business delivery.

As organizations strive to better understand and manage their cryptographic footprint, it is important to consider implementing an *organization wide Cryptographic System of Record* (CSOR). A CSOR should be part of an organization's risk management framework and serve as a way to monitor and ensure that the organization is tracking all cryptographic assets and complying with all policies and procedures when it comes to managing the entire Cryptographic service and delivery life cycle. It should act as a central repository from which an organization can monitor and maintain all of the Cryptographic Policy Orchestration tools outlined above.

Given the sensitive nature of the CSOR, it is critical that it exist entirely outside of the active cryptographic service and delivery work flows so that it can be securely updated, monitored, and controlled in real time. A CSOR will become a critical addition to organizations as standards bodies seek to embrace Crypto Interoperability and a Crypto Agile mindset. Acting as a single point of accurate information for the entire organization, a CSOR can help enhance the organization's security posture by:

1. Accelerating remediation cycles in the event of broken or deprecated cryptographic algorithms or primitives.
2. Ensuring that the organization is up to date with the latest international standards in relevant technologies and maintains compliance with regulatory requirements.
3. Allowing for an organization to dynamically update Cryptographic Bill of Materials (CBOMs) in a Cryptographically Agile environment]
4. Ensure organizational governance and audit teams can assess systems to ensure compliance with IT security policies derived from regulatory requirements and security controls.
5. Saving time and money by removing the need for manual audits in the future as once a CSOR is properly installed and maintained, organizations may not need to provide manual audits of their Cryptographic infrastructure.

6.4 Cryptographic Interoperability

Cryptographic interoperability is critically important in today's interconnected, digital world. Interoperability is commonly achieved through the use and adoption of standards. These standards are developed collaboratively and undergo rigorous review and testing by the cybersecurity community. Organizations are advised to use open standards based cryptographic protocols. Examples of organizations that produce open standards include ISO, IETF, and ANSI-accredited bodies such as X9 and NIST.

© ASC X9 Inc., 2025 – All Rights Reserved

An organization evaluating readiness for PQC adaptation is well advised to review (during inventory) the extent that their solutions and systems depend on open standards or on proprietary / custom libraries, algorithms, implementations, and then consider update. Here are some key points highlighting the importance of interoperable cryptographic solutions based on public standards:

1. **Secure Communication and Data Exchange**: Interoperable cryptographic systems ensure secure data exchange between different entities, regardless of their underlying technologies. This seamless communication fosters trust in digital interactions by safeguarding sensitive information from unauthorized access, tampering, and eavesdropping.
2. **Global Trust and Adoption**: Public standards enjoy broad acceptance and trust across industries, governments, and international communities. When cryptographic solutions adhere to these standards, they are more likely to gain global adoption due to their proven security and reliability, promoting consistency and coherence in secure communication practices worldwide.
3. **Avoiding Vendor Lock-In**: Interoperability based on public standards prevents organizations from being locked into proprietary cryptographic solutions. Instead, they can choose from a variety of compliant products, fostering healthy competition among vendors and allowing for flexible integration and future scalability.
4. **Regulatory Compliance**: The financial industry has very specific regulations including governance, risk and compliance requirements concerning data protection and encryption. Cryptographic solutions based on public standards help ensure regulatory compliance, as they align with industry best practices and established security measures.
5. **Reducing Complexity and Integration Challenges**: Public-standards-based cryptographic interoperability simplifies integration across diverse systems, applications, and networks. With well-documented interfaces and compatibility guidelines, organizations can more easily integrate cryptographic solutions into existing infrastructure, reducing implementation complexity and minimizing errors.
6. **Future-Proof Security**: Public standards are regularly updated and improved to address emerging threats and vulnerabilities. Cryptographic solutions that adhere to these evolving standards are better equipped to withstand new security challenges and maintain robust protection against cyber threats.
7. **Cross-Platform Compatibility**: Interoperable cryptographic systems can function seamlessly across different platforms, operating systems, and devices. This compatibility is crucial in today's diverse computing environment, where users expect secure communication and data exchange across various devices and networks.

6.5 Cryptography Policy Orchestration

Effective cryptography policy orchestration requires not only continuous monitoring but also the proactive definition and automated enforcement of rules across all cryptographic systems and services. By leveraging a centralized Cryptographic System of Record (CSOR) and a crypto-agile architecture, organizations can ensure that their cryptographic assets—and the sensitive data they protect—remain compliant and resilient against both classical and quantum-era threats.

Organizations would be well advised to review (during inventory), consider & update the extent of policy-based / centralized cryptographic orchestration in their systems – to achieve a more flexible infrastructure.

The capabilities below illustrate how to achieve this in practice:

1. **Cryptographic Policy Definition**: Define and periodically review the organization's cryptographic policies—encompassing encryption algorithms, key management practices, certificate usage, and module requirements—to keep pace with evolving quantum threats. Ensure cross-department collaboration (IT, Legal, Compliance) in policy creation for comprehensive coverage.

© ASC X9 Inc., 2025 – All Rights Reserved

2. **Cryptographic Module Validation**: Employ both in-house and third-party validation tools to confirm that cryptographic modules/libraries meet industry standards and policy requirements. Formal certification and ongoing compliance checks are critical—especially for high-risk or regulated systems. Note: 1) remediation 2) certification, 3) on going compliance.[6]
3. **Key Management Software**: Deploy scalable key management solutions capable of handling both classical and post-quantum keys. Automate key generation, distribution, rotation, and destruction to minimize human error—and ensure seamless migration to quantum-safe algorithms.
4. **Certificate Management**: Leverage automated lifecycle tools to issue, renew, revoke, and track certificates. Build in a migration path to quantum-safe certificates without service interruption, and integrate reporting on certificate status and compliance.
5. **Hardware Security Modules (HSMs)**: Use HSMs that support emerging PQC algorithms to protect master keys during migration. Ensure firmware updates and PQC-capable interfaces are part of your vendor roadmap to avoid lock-in with legacy-only devices.
6. **Crypto-Auditing Tools**: Integrate audit-trail analysis into your tooling so you can continuously verify configurations, flag deviations, and generate compliance reports. Include real-time alerts for unauthorized changes.
7. **Integrity Checking:** Extend monitoring to verify key integrity—especially when running hybrid classical/PQC setups. Use file-integrity monitoring agents to detect tampering in real time and trigger automated remediation.
8. **Continuous Monitoring**: Employ continuous monitoring solutions to detect and respond to any anomalies or security breaches related to cryptographic assets promptly.
9. **Security Information and Event Management (SIEM):** Use SIEM tools to correlate and analyze cryptographic-related events and logs, assisting in detecting and mitigating potential security incidents. Create PQC-specific correlation rules to identify quantum-related attack patterns. Ensure SIEM covers logs from HSMs, key managers, and certificate authorities for a consolidated threat view.
10. **Digital Signatures and Authentication:** Utilize software that enforces the proper use of digital signatures and authentication mechanisms to prevent unauthorized access and tampering of data.
11. **Cryptographic Algorithm Compliance:** Ensure that software and systems use approved cryptographic algorithms in accordance with the organization's policies and industry best practices.
12. **Secure Communication Protocols**: Use appropriate software tools to identify and enforce the use of secure communication protocols (e.g., TLS/SSL) to protect data during transmission. Phase out older protocols in a risk-based order, beginning with internet-facing services.
13. **Cryptographic Policy Enforcement:** Implement software-based enforcement mechanisms to ensure that cryptographic policies are consistently applied across the system.
14. **Auditing and Reporting:** Set up automated reporting and auditing mechanisms to monitor and report on cryptographic policy compliance regularly. When possible, use a unified dashboard to aggregate compliance metrics across all environments
15. **Training and Awareness:** Create role-based training modules for IT, DevOps, compliance, and executive teams. Include hands-on labs for generating, deploying, and rotating PQC keys so each group understands their specific responsibilities.

By integrating these software tools and practices, organizations can proactively monitor cryptographic policy compliance, detect vulnerabilities early, and ensure that cryptographic assets are continuously safeguarded against evolving threats. Regular threat modeling, policy updates, and assessments of new cryptographic standards are vital to stay ahead of emerging risks, particularly in the face of quantum computing advancements. These ongoing improvements will ensure that organizations maintain a resilient and adaptive cryptographic infrastructure, capable of supporting long-term security needs in a dynamic threat landscape.

[6] NIST Cryptographic Module Validation Program

© ASC X9 Inc., 2025 – All Rights Reserved

7 Design Trade-offs and Identifying Dependencies

When migrating to post-quantum cryptography (PQC), it is essential to consider the following:

1. dependencies between different cryptographic systems and components. For example, in some cases, master keys must be migrated to PQC before subkeys.
2. the order in which different PQC systems and components should be implemented. This will help to minimize disruption and ensure a smooth transition.

Approaches for this consideration:

1. **Dependency graph:** audit cryptographic systems and create a dependency graph based on the relationships identified. A dependency graph visually represents the relationships between systems and components. It helps identify which elements must be migrated to PQC first and which can follow.
2. **Risk-based approach:** identify the systems and components that are most at risk from quantum attacks, and migrating those systems and components first. Note: Upstream or downstream components may need to be migrated before—or concurrently with—the main component.

It may be beneficial to first migrate a lower-value, smaller project to gain insight and experience.

After identifying dependencies and determining the order of implementation, organizations should develop a migration plan that outlines the steps required to transition each system and component to PQC. The plan should also include a timeline for the migration and a budget.

Here are some specific examples of dependencies and order of implementation considerations for PQC migration:

- **Master keys:** Master keys should be migrated to PQC first. This is because the master keys are used to generate and manage the subkeys.
- **Subkeys:** Subkeys can be migrated to PQC after the master keys have been migrated.
- **Cryptographic Protocols**: Cryptographic protocols should be migrated to PQC in a coordinated manner. This will help to ensure that all systems and components are using the same PQC algorithms and protocols. [See section titled Standards, Polices and Procedures for more details.]
- **Systems and applications:** Systems and applications should be migrated to PQC in a way that minimizes disruption. This may require migrating some systems and applications first, and others later.

It is important to note that there is no one-size-fits-all approach to determining dependencies and order of implementation for PQC migration. The specific dependencies and order of implementation will vary depending on the organization's specific needs and environment.

Organizations should carefully consider the dependencies and order of implementation when migrating to PQC. By doing so, they can minimize disruption and ensure a smooth transition.

8 Certificate Implementations and Interoperability

There are several options for transitioning from classic certificates to quantum-safe versions. This is still an area of very active investigation, and the standards are still evolving. Even basic questions—such as what a quantum-safe Certificate Signing Request (CSR) should look like—have yet to be answered. But several strategies for quantum-safe certificates are being considered.

© ASC X9 Inc., 2025 – All Rights Reserved

Some techniques include both a classical and quantum-safe component in order to hedge against potential problems with either algorithm, while others only use quantum-safe algorithms. If two certificates (old and new) are being used during a transition period, there is a proposal for a binding mechanism between the two.[7]

In addition to certificates, supporting technologies and protocols must also be upgraded. These include but are not limited to CRLs, CSRs, OCSP, time stamping, certificate transparency SCTs, and so on.

8.1 Pure Quantum-safe Certificates

The simplest approach to creating a quantum-safe certificate is to use a quantum-safe signature algorithm in place of RSA or ECC. Algorithm OIDs are available for ML-KEM, ML-DSA and SLH-DSA on the NIST website.[8]

Once the new algorithms are available in a crypto library, it is relatively straightforward to include them into a certificate in the standard way. The IETF LAMPS draft “draft-ietf-lamps-dilithium-certificates” describes how this will likely work for ML-DSA. The IETF LAMPS draft “draft-ietf-lamps-kyber-certificates" describes how this will likely work for ML-KEM. Both drafts are proceeding through the IETF publication process.

If the quantum-safe component or its implementation fails unexpectedly, systems using such certificates could become vulnerable.

8.2 Composite Quantum-safe Certificates[9]

A composite quantum-safe certificate contains a single key made up of two components: a classical key and a quantum-safe key. It is referred to as a composite key because it combines the two parts, typically by concatenating them. Standards in this area are still being developed but they are maturing rapidly. When signing with a composite key, signatures are generated with each key individually, and then concatenated. This produces a composite signature. Verification is similarly pairwise. The advantage is that in the event of an implementation flaw in the quantum-safe algorithm, the classical algorithm still provides protection against non-quantum attacks.

Note that each individual signature is also independently valid. The security risks of this need to be carefully considered in cases where that matters. For secure operation, both components of the signature need to be verified, and the verification must fail if either verification fails.

8.3 Related Certificates

In both of the above cases, a user or device may have both an old (classic) and new (native or composite) certificate during a transition period. During the transition, linking the two certificates can help ensure proper management. A scheme for doing this is described in the IETF RFC 9763.[10]

8.4 Chameleon Certificates

Chameleon certificates are a clever way of supporting backwards compatibility, while only having to manage a single certificate. A chameleon certificate appears to be a quantum-safe certificate (native or composite), but has additional information in an extension that allows a legacy classic certificate to be re-generated and used. This enables quantum-aware systems to extract and use a legacy certificate when communicating with legacy systems. This is similar to the older two-key certificate proposal described below, but it offers several advantages:

---

[7] https://datatracker.ietf.org/doc/draft-ietf-lamps-cert-binding-for-multi-auth/

[8] https://csrc.nist.gov/projects/computer-security-objects-register/algorithm-registration/

[9] https://datatracker.ietf.org/doc/draft-ietf-lamps-pq-composite-sigs/

[10] https://datatracker.ietf.org/doc/html/rfc9763

© ASC X9 Inc., 2025 – All Rights Reserved

1. Since the classic key is small compared to the post-quantum key, its inclusion in quantum-safe certificates is relatively cheap
2. The size of existing classic certificates is unchanged, and doesn't drag along a large, unnecessary key.
3. Since a quantum-aware system makes the decision about which cert to send to legacy systems, it can make policy decisions without requiring negotiation and being vulnerable to downgrade attacks.
4. This allows the interface between server and the CA to be unchanged when requesting multiple certificates for a single subject.
5. It reduces duplication as the components of the certificate that refers to the subject is only included once.

While interesting, this idea is highly experimental and only beginning to be explored. It is described in the independent draft "draft-bonnell-lamps-chameleon-certs".

8.5 Dual-Key Certificates

Dual-Key certificates are more complicated, and require a bit more background. In principle, they allow both keys to be managed in a single certificate, and allow systems that do not have quantum safe support to ignore the additional key. In practice, in many contexts and protocols, active network attackers can force a downgrade to the "old" version, limiting the utility of this approach during a transition. The exact details depend on the application, protocol, environment, and transition strategy. It also has the downside that the large post-quantum key is always transmitted, even when it is not necessary or even understood by the other system. (The certificate formatting for this approach is standardized in Rec ITU-T X.509:2019.)

9 Compliance Assurance

Vendor affirmations that a product, process, or service complies with a given standard—or meets other stated requirements—are typically insufficient. If a product claims to achieve certain properties, and a user assumes the claim to be true, then there can be significant risk to that user if in reality, the claim is false. In particular, the risks associated with unverified or uncertified cryptography can be especially significant. Therefore, to validate vendor claims and reduce user risk, products should undergo objective, formal verification and certification to ensure the requirements are met.

Often, for mature technologies, there are corresponding mature standards and certification and validation processes which vendors and users can rely on. Unfortunately, for nascent technologies, there simply has not been enough time for the relevant standards and certification and verification processes to develop. This is especially true for post-quantum cryptography products.

To avoid subtle misconceptions, the following definitions can be helpful.

- **Evaluation:** The process of evaluating the validity of the request that is presented.
- **Verification:** Confirms that the design is capable of meeting all stated requirements.
- **Validation:** Provides objective evidence that the product meets those requirements.
- **Certification:** Formal recognition that the product has successfully passed validation.

There is often some confusion between verification and validation. Roughly speaking, verification is something of a sanity-check. It is a process to ensure that the system is designed in such a way to achieve all stated requirements, even if the system has not actually been built yet. The goal is to verify the design's suitability—that is, to answer the question, "Will the product meet the requirements?"

© ASC X9 Inc., 2025 – All Rights Reserved

Validation occurs after the product has been built. When the product is validated, it is objectively tested and investigated to see whether the stated requirements have been met. The goal is to validate the claims of compliance—that is, to determine, "Does the product meet the requirements?"

Certification is nothing more than a formalization of the compliance claims. Certification is often compared to earning a diploma or academic degree. It is a formal statement from the relevant authority (e.g., the college or university) that the requirements of the program have been achieved. At the end of the program, an authority reviews that all degree requirements have been met (validation), and if so, issues the degree (certification).

It can also be helpful to draw a distinction between the terms "compliance" and "assurance."

- **Compliance:** Demonstrated ability to meet (i.e., conform to) stated requirements.
- **Assurance:** Pertains to the level of trust and confidence in the quality of the product (e.g., the security level provided).

Some standards provide different levels of assurance, where a higher assurance level instils higher confidence in the security properties of the product. For example, the seven Evaluation Assurance Levels (EALs) of the Common Criteria (CC). Cryptographic Module Validation Program (CMVP)[11] provides four different levels which cryptographic hardware security modules (HSMs) can be validated against. To be clear, a higher level of assurance is not simply the result of "looking more closely" at the product. Rather, it is the result of compliance validation and certification of the product against a more stringent set of requirements. The more stringent the requirements, the higher the resulting assurance level.

Below, are some compliance and assurance considerations for the use of post quantum cryptography.

Requirements gathering:

- Which standards, laws, regulations, policies, contractual agreements, etc. does the product need to be compliant with?
    - Are those requirements finalized, or are they still under development?
- What level of compliance is necessary?
    - Is a claim of compliance enough, or is formal certification required?
- Which bodies are responsible for creating or maintaining the given requirements?
- Are there requirements for the specific environment in which the product will be used?
    - In a hybrid or multi-cloud environment?
    - In different geographies?
- What are the impacts of upcoming changes to requirements?
    - Impacts to internal technological roadmaps?

Compliance and assurance:

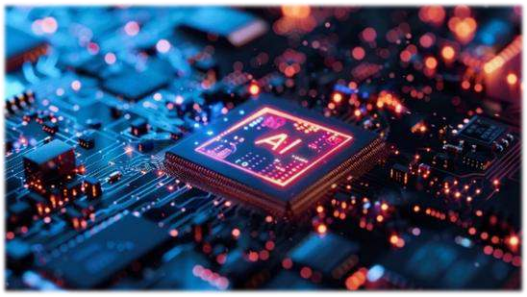
- What compliance level is required?
- What assurance level is required?
- Who is responsible for completing verification, validation, or certification?
    - Internal or external auditors?
- Are validation authorities available?
    - Does an entity exist who can provide validation and certification (e.g., through the Cryptographic Module Validation Program (CMVP))?

[11] https://csrc.nist.gov/Projects/Cryptographic-Module-Validation-Program

© ASC X9 Inc., 2025 – All Rights Reserved

- What are the time or resource constraints for obtaining the required assurance or compliance levels?
- If the requirements are not yet set, what compensating solutions can be implemented for the time being?
    - Can the product use post quantum cryptography in a hybrid mode with standardized cryptography in a way which maintains (or enables) certification?

10 What New Attacks Could Result from Combining Quantum Computers and AI



The combination of artificial intelligence (AI) and quantum computing has the potential to create new and formidable attack vectors by merging AI's pattern recognition capabilities with quantum computing's exponential problem-solving power. While such threats remain speculative at this stage, they warrant attention as both technologies continue to mature. The key takeaway is that these AI–quantum hybrid threats could accelerate the urgency of adopting post-quantum cryptography (PQC) and implementing crypto-agile systems that can quickly respond to future cryptographic changes. For further reading, see the referenced Springer document. For further reading on the topic see the Springer Document.[12]

11 Consider Cloud Service Providers a Vulnerable Point in IT Infrastructure

Engaging with cloud service providers (CSPs) for post-quantum cryptography (PQC) readiness requires a collaborative and proactive approach. Financial institutions must work closely with their CSPs to ensure the appropriate security measures are in place to protect sensitive data from emerging quantum threats. Here's a step-by-step guide that can help a financial institution can handle this process:

1. **Assessment of New Cloud Vendor**: Financial institutions should begin by evaluating a cloud provider's readiness for post-quantum cryptography (PQC). Review their cryptographic protocols, encryption schemes, and key-management processes—specifically how keys are generated, stored, distributed, and rotated. Robust key management underpins long-term data security in a quantum-threat environment.
2. **Foster Communication and Education**: Engage your provider in candid discussions about PQC—its impact on data security, the risks quantum computing poses to today's cryptographic schemes, and the critical need to adopt quantum-safe algorithms.
3. **Obtain a PQC Readiness Plan**: Ask the provider for a comprehensive plan detailing how they will integrate PQC—complete with timelines, milestones, and implementation steps for quantum-safe cryptography.
4. **Verify Key Management**: Confirm the provider's processes for key generation, storage, distribution, and rotation under PQC. Effective key management is essential for maintaining data confidentiality.
5. **Testing and Validation**: Work with the provider to test PQC solutions in their environment, evaluating performance, interoperability, and security against quantum-resilient criteria
6. **Security Compliance and Auditing**: Require your provider to meet applicable security standards and submit to periodic audits. Confirm they maintain robust controls capable of withstanding quantum-era threats.

[12] https://link.springer.com/chapter/10.1007/978-3-031-22356-3_15

© ASC X9 Inc., 2025 – All Rights Reserved

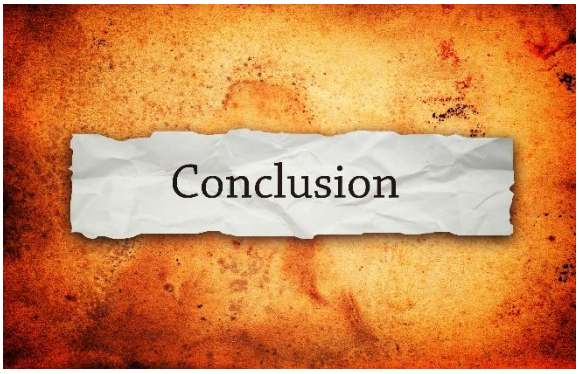
7. **Crypto-Agility and Future-Readiness**: Verify the provider's ability to smoothly adopt new quantum-safe algorithms and deprecate old ones. This agility is essential to stay ahead of evolving quantum threats.
8. **Service Level Agreements (SLAs)**: Review and revise, if necessary, SLAs to specify PQC readiness requirements, data-security metrics, and escalation procedures. Clearly define both parties' responsibilities for cryptographic safeguards.
9. **Ongoing Collaboration and Monitoring**: Set up periodic reviews and joint working sessions to track the provider's PQC implementation progress. Continuously monitor their security posture for compliance and performance.

By proactively collaborating with cloud storage providers on PQC readiness, financial institutions can strengthen their security posture and safeguard sensitive data against future quantum-enabled threats.

12 Related Work by X9

At the time of publication, the X9F1 work group was developing a technical report titled *Post-Quantum Computing Assessment Guideline* (X9.61). This report will outline objectives and criteria that organizations can use for self-assessment, informal evaluation of third-party service providers, or independent assessment by qualified information security professionals. Historically, similar X9 reports have been adopted by auditors. For the latest status of this report (X9.61), please visit the X9 website.

13 Conclusion



This *Post-Quantum Cryptography Financial Industry Readiness Needs Assessment* serves as a vital resource for the financial sector to understand and prepare for the paradigm shift in cryptographic standards introduced by quantum computing. The report explores the impact of quantum computing on current cryptographic methods and emphasizes the urgency of adopting post-quantum solutions to safeguard critical financial data and transactions.

By offering a comprehensive analysis of the industry's readiness for post-quantum cryptography, this report highlights vulnerabilities and challenges that demand timely attention. It underscores the importance of proactively updating cryptographic standards, policies, and practices to ensure data security and privacy against evolving quantum threats.

The report's findings and recommendations equip financial institutions with the insights needed to develop a robust crypto-agility strategy. A crypto-agility platform enables the industry to track and remediate cryptographic technical debt efficiently, helping it stay ahead of quantum adversaries and maintain a strong security posture.

As the financial sector navigates this transformative cryptographic era, the insights from this needs assessment will be instrumental in building secure, resilient infrastructure to withstand quantum-era challenges. By proactively adopting post-quantum solutions, institutions can strengthen trust, instil confidence among stakeholders, and ensure the integrity of their operations in an evolving cybersecurity landscape.

© ASC X9 Inc., 2025 – All Rights Reserved

Annex A – NIST-Approved Post-Quantum Cryptographic Algorithms

On August 13, 2024, NIST released the first three cryptographic algorithms approved as quantum-safe or resistant. A Federal Information Processing Standard (FIPS) was published for each. A summary of the algorithms follows.

The first set of NIST algorithms consists of:

- FIPS 203 Module-Lattice-Based Key Encapsulation Mechanism (ML-KEM) derived from CRYSTALS-KYBER. This general-purpose algorithm allows two parties to establish a shared secret resistant to quantum attacks. That secret can then be used to encrypt data and ensure integrity. ML-KEM is based on structured lattices and is known for its speed and efficiency.
- FIPS 204 Module-Lattice-Based Digital Signature Algorithm (ML-DSA) derived from CRYSTALS-Dilithium. This lattice-based signature algorithm is designed for general use, offering relatively small keys and signatures, and fast performance in key generation, signing, and verification.
- FIPS 205 Stateless Hash-Based Digital Signature Algorithm (SLH-DSA) derived from SPHINCS+. This stateless hash-based signature scheme is highly robust but may be less practical for some applications due to slower signing speeds and larger signature sizes.

With the official NIST release of these quantum-safe algorithms, X9 will work to incorporate them into standards for the U.S. financial services industry. For more information, contact X9.

The NIST announcement can be viewed at the following URL:

Click on this Link to go to the NIST Web Site

© ASC X9 Inc., 2025 – All Rights Reserved

End of Document

© ASC X9 Inc., 2025 – All Rights Reserved